IT 信息安全管理手册

版本日期：2024-6-7

1 总则

1.1 适用范围

本制度适用于上海近铁国际物流有限公司（包括但不限于所关联公司）的全体员工（包括但不限于所有签订劳动合同而受聘的员工、以劳务派遣形式或其他形式受雇于公司的员工等)。

1.2 管理方针

安全第一，预防为主；

完善制度，综合防范；

全员参与，强化培训。

1) 在公司内各层次建立完整的信息安全管理组织机构，确定信息安全方针、安全目标和控制措施，明确信息安全的管理职责；
2) 识别并满足适用法律、法规和客户等相关方信息安全要求；
3) 采用先进有效的设施和技术，处理、传递、储存和保护各类信息；
4) 对全体员工进行持续的信息安全教育和培训，不断增强员工信息安全意识和能力；
5) 对于基本方针的适用性、充分性，结合实际状况定期自查，必要时予以修订。

1.3 编制目的

为提高上海近铁国际物流有限公司的信息安全管理水平，防止

由于信息系统的中断、数据的丢失、敏感信息的泄密所导致的公司和客户的损失，规范操作流程，维护网络正常运行，确保计算机信息系统的安全，保障公司业务活动的正常进行而制定本制度。

2 IT 设备管理规范

2.1 IT 设备及管理综述

IT 设备:是指公司业务运作所使用的 PC 机、笔记本、服务器、网络设备、打印机、U 盘、移动硬盘、投影仪、会议电话等设备

从资产使用管理人，使用部门，使用场所等角度进行登记并管理。分以下 3 类。

1) 个人使用设备：台式电脑、笔记本电脑等，由员工个人对 IT 设备使用和管理，并记录其常用办公区域。
2) 部门使用设备：扫描枪、打印机、硬盘 U 盘等，分散于各个部门办公区域，由部门员工使用，部门相关负责人或仓库负责人进行管理。
3) 其他公共设备：会议室投影设备、服务器等，记录其所在区域，由 IT 部统一管理。

2.2 IT 设备新增及接入安全管控

1) 当需要新增 IT 设备时，必须由部门根据公司 JDY 申请流程进行请购申请，经各级领导审核批复后，交 IT 部完成 IT 设备采购。

2）未经 IT 部确认的 IT 设备，不得连入公司内部网络。如确实需要接入需报备 IT 后由 IT 人员实施接入动作。

2.3 IT 设备使用规范

1）员工必须爱惜自己名下使用的 IT 设备。公司所有人员应保持清洁、安全、良好的计算机设备工作环境，禁止在计算机应用环境中放置易燃、易爆、强腐蚀、强磁性等有害计算机设备安全的物品。

2）分配到员工或部门使用的设备，员工一旦开始使用后，即成为该设备的保管人，并承担相应的保管及赔偿责任。

3）员工原则上只能使用本部门分配的计算机。未经当事人同意，不能擅自在他人的计算机上进行任何操作。

4）未经 IT 部授权同意，不得擅自改变台式机和打印机的位置。

5）严格遵守计算机设备使用、开机、关机等安全操作规程和正确的使用方法。未经 IT 部授权同意，不得擅自拆、换 IT 设备的零件、配件及外设。计算机出现故障时应及时向信息管理部报告，不允许私自处理和维修。

6）发现由以下等个人原因造成硬件的损坏或丢失的，其损失由当事人如数赔偿：违章作业；保管不当；擅自安装、使用硬件和电气装置。

7）公司每位员工对自己的工作电脑既有使用的权利又有保护的义务。任何的硬件损坏必须给出损坏报告，说明损坏原因，不得擅

自更换。公司会视实际情况进行处理。

8) 下班后所有不再使用的计算机，应关闭主机电源，以防止意外。

2.4 IT 资产盘点

1) IT 部每年例行对 IT 资产进行盘点，通过扫描，表格比对等进行盘点。

2) 根据盘点形成盘点报告，与业务部门相关设备负责人核实确认，针对变动信息及时调整固定资产系统，确定设备损坏或报废的也要及时处理。

2.5 IT 设备遗失

IT 设备发生遗失时，由固定资产系统中登记的该设备的使用人或保管人核实确认设备去向，根据实际情况处理。

3 防病毒软件使用&安全补丁升级

3.1 员工职责

1) 每名员工有责任查看本机是否安装了经批准版本的反病毒软件，是否最新病毒定义，如未安装需立刻联系 IT 部 HELPDESK。

2) 任何工作人员不得制作和传播计算机病毒。

3) 任何工作人员不得有下列传播计算机病毒的行为：

   a) 故意输入计算机病毒，危害计算机信息系统安全。

   b) 向计算机应用部门提供含有计算机病毒的文件、软件、媒

体。

c） 购置和使用含有计算机病毒的媒体。

3.2 自动更新

1） 所有 WAN 内的设备，按 IT 设定规则进行自动更新。

2） WAN 外的设备通过 Internet 及其他方式更新。

3.3 反病毒软件禁用

1） 在任何时候，未经批准，反病毒软件是不能被停用的，只有当 IT 需要时才能暂时停用（如安装或调试新的软硬件设备）。

2） 所有计算机必须安装经批准的防病毒软件。

3） 所有计算机必须安装经批准的防病毒软件且保证能正常运行，才能交给员工使用。

3.4 非近铁设备连接到近铁公司的网络

任何经批准连接的计算机设备，必须安装认可的病毒软件且保持最新的病毒定义。

3.5 紧急措施

为防止病毒传播到其他网络设备或带来的不利影响，当感染以网络传播方式的电脑病毒或其他形式的恶意代码（统称为“病毒”或“木马”）时，应断开网络直到病毒被删除。

3.6 紧急修补程序安装

如有重要的安全补丁需要安装，员工必须配合立刻在电脑上安装。

3.7 非强制性更新

为了保持公司所有机器的一致性，非安全相关的应用程序补丁及更新要求，需经 IT 部核查后再行发布安装。

4 病毒检测和网络安全漏洞检测制度

1) 网络（内部信息平台）的服务器，只有授权 IT 人员才能进行相应权限范围内的操作，任何其他非法操作都属于入侵行为。
2) 所有用户，不准扫描端口，不准猜测和扫描其他用户的密码，不准猜测和扫描网络（内部信息平台）的服务器和交换设备的口令。
3) IT 应定期检查服务器的系统日志，如发现有入侵情况，应及时采取措施，保留原始数据，以便进行调查取证，并向领导汇报，做好入侵情况登记。
4) 服务器如果发现漏洞要及时修补漏洞或进行系统升级。
5) 定期对网站进行网络（内部信息平台）数据包的监控，及时发现网络（内部信息平台）异常运行情况，全面监视对公开服务器的访问，及时发现和拒绝不安全的操作和黑客攻击行为，阻止网络

（内部信息平台）内外的入侵。

6）网络（内部信息平台）信息安全员履行对所有上网信息进行审查的职责，根据需要采取措施，监视、记录、检测、制止、查处、防范针对其所管辖网络（内部信息平台）或入网计算机的人或事。

7）所有员工有责任对所发现或发生的违反有关法律，法规和规章制度的人或事予以制止或向 IT 部反映、举报，协助有关部门或管理人员对上述人或事进行调查、取证、处理，应该向调查人员如实提供所需证据。

8）网络（内部信息平台）管理员应根据实际情况和需要采用新技术调整网络（内部信息平台）结构，系统功能，变更系统参数和使用方法，及时排除系统隐患。

5 电子信息处理

5.1 电子邮件系统使用规范

员工在日常工作和业务往来中，均应使用公司统一的电子邮件账户(即 Username@ kwe.com.cn)。

5.2 电子信息处理中的不当行为

1）非职务所需，下载传送及使用 MP3、VCD、游戏软件及其它聊天或娱乐功能之软件工具或系统。

2）利用公司网络从事与工作无关的行为。

3) 非经主管授权使用便携式储存设备（移动硬盘、U 盘、光盘、软盘等）储存业务相关数据（所有信息皆应只储存于该电脑硬盘或备份于 SERVER 中）

4) 非经授权将公司机密文件传送给非相关职务员工或公司外人员。

5) 传送涉及损害、骚扰、攻击、恐吓、侮辱及毁谤他人名誉的电子邮件或其他不实的谣言与信息。

6) 恶意散布计算机病毒。

7) 未经许可擅自篡改、损毁、删除、窃取或盗用公司服务器上的数据、信息、档案及软件，或更改服务器的设定。

8) 其他未列于上的不当行为。

9) 员工如发生以上不当行为，将根据公司规章制度处理。

6 计算机软件使用

6.1 软件安装

1) 员工使用的计算机上的全部软件由 IT 部 HELPDESK 统一进行安装，所有经过 IT 部 HELPDESK 安装的软件为公司认可的可以运行的软件。

2) 员工有特殊工作需要安装非 IT 部统一安装的软件时，员工应联系 IT 部 HELPDESK 并递交软件安装申请，经审批后由 IT 部 HELPDESK 对该用户计算机进行软件的安装。

3) 员工使用公司计算机时，应该严格遵守公司的劳动纪律及规范，不得在公司的计算机中安装及使用与公司工作业务无关的应用软

件（如计算机游戏，股票软件，网上聊天软件等）。

4）不得在公司的计算机中安装无许可证的软件（即盗版软件）。

6.2 软件变更

员工在使用公司的计算机办公时，未经过相关管理部门允许，不得私自对公司的计算机上安装的软件进行改动，删除，变更等操作。

6.3 软件监控

管理人员定期检查用户计算机软件的运行状况、定期调阅软件运行日志记录，对于工作无关的软件使用情况进行记录。

7 数据中心管理

7.1 数据中心日常管理

1）非 DC 工作人员进入数据中心，需得到数据中心管理人员的同意。

2）数据中心内严禁吸烟、饮食、嬉戏，保持数据中心安静。

3）数据中心用品要各归其位，不能随意乱放。未经主管领导同意，不能将任何设备和物品带出数据中心。

4）建立数据中心登记制度，对本地局域网络、广域网的运行，建立档案。对所发生的故障、处理过程和结果等做好详细登记。

5）DC 人员应对服务器的各种帐号及密码严格保密，并定期更改。

7.2 数据中心设备管理

1) 对中继、光纤、网络等线路设备的任何调试，原则上不能影响公司日常业务，并在调试前通知相关人员。
2) 定期做服务器操作系统的补丁修正工作。
3) DC 人员统一管理数据中心的所有设备，完整保存其设备的驱动程序、保修卡及重要随机文件。
4) 数据中心所有设备的报废需经过管理部门或专职人员鉴定，确认符合安全要求后方可报废。
5) 对于使用过程中损坏、消耗、遗失的物品应汇报登记，并对责任人追究相关责任。
6) 建立对空调和 UPS 的检查和监控的机制。

7.3 数据中心数据备份

1) 业务数据必须定期、完整、真实、准确地转储到不可更改的介质上，并要求集中和异地保存，保存期限至少 3 年。
2) 每月制作数据的备份并异地存放，确保系统一旦发生故障时能够快速恢复，备份数据不得更改。
3) 重要资料、文档、数据应采取对应的技术手段进行加密、存储和备份，对于加密的数据应保证其可还原性，防止遗失重要数据。

8 机房管理制度

8.1 日常管理规定

1）到机房工作的人员不得在机房内吃食品，饮水，吸烟或其他与工作无关的事宜。

2）到机房工作的人员严禁携带与工作无关的物品，特别是易燃、易爆、强磁、腐蚀性物体等危险物品进入机房。

3）到机房工作的人员应严格遵守岗位责任制，不能乱动与自己工作无关的设备，严禁在机房大声喧哗、玩电子游戏、聊天等。

4）机房内不能存放任何食品，严禁在机房内存放杂物，严禁在机房内使用其他用电器。

5）无关人员不准进入机房，不准违规操作和使用机房设备，不准私自将机房设备带离机房。机关科（室）需借用机房设备的，机房工作人员必须上报，经分管领导同意，并办理有关登记手续后方可借出。

8.2 防护管理措施

做好防雷、防火、防水、防盗、防虫害。

1）防雷：按国家的规定对机房的设备进行接地。每年要按国家的规定对防雷设施及设备接地进行检测。

2）防火：需按国家的规定在计算机机房进行设置消防设施。设施每年要按国家规定进行检测。

3）防水：要经常检查机房的防漏水情况，空调、门窗及屋顶。

4）防盗：严格机房进出管理，门禁要 24*7 小时工作，严格执行进

出机房的登记制度、严格执行进出机房不得携带其他物品的规定。

5）防虫害：经常检查机房的顶棚上和地板下的封闭情况，不得在机房内在放食品，不得在机房内堆放杂物。

9 网络安全

9.1 员工网络使用

1）员工在使用公司网络时，未经 IT 部允许，不得登录公司网络中的服务器、路由器、交换机及其他网络设备。

2）员工因工作需要登录公司网络中的服务器及其他网络设备时，须递交 IT 软硬件申请并经过批准。

3）员工在使用公司网络时，不得在公司网络中建立与工作无关的共享文件夹。

4）员工在使用公司网络时，不得入侵其他员工的计算机。

5）员工在使用公司网络时，未经过 IT 部允许，不得使用网络传送与工作无关的文件。

6）员工在使用公司网络时，只能使用 IT 部分配的 IP 地址。

7）员工不得将非公司设备接入公司网络。要特殊业务需要，必须连接的，须递交 IT 软硬件申请并经过批准。IT 部须确认该设备为安全状态后（防病毒库更新未过期，系统未存在安全漏洞等），方可接入公司网络并使用，如未经 IT 确认私自接入，经 IT 部核查确认属实后，IT 部将通报该员工上级主管及相关部门

负责人。

9.2 外来人员网络使用

外来人员使用公司网络，须获得 IT 部批准，由 IT 部进行网络配置后，方可以有限使用相关网络资源，如外来人员未获得 IT 部批准私自接入公司网络，经 IT 部核查确认属实后，IT 部有权利立刻终止该外来人员使用公司网络，并通报相关部门负责人。

10 供应商选择的规定

1) 供应商的选择本着公平公开公正的原则，入选供应商必须是有正规的营业资质。
2) 任何项目进入供应商选择阶段前，必须形成 RFP，在统一的时间发给项目涉及的供应商。
3) 没有获得 RFP 或没有按时提交方案的供应商将不在考虑之列。
4) 在选择供应商的整个过程中，形成供应商选择报告，按考察的方面对供应商进行评级和说明，最终体现入选供应商及入选理由。此报告须以公开的方式在项目组内部共享。

11 远程访问

11.1 一般说明

1) 远程访问公司内部网络的功能仅给予那些有重要业务需要支持的员工。

2) 必须确保远程访问被严格控制；主要包括员工用户名及密码认证。

3) 员工在任何时候不能将系统及邮件登录密码告诉其他人。

4) 所有进行远程访问的主机，必须确保防病毒定义及操作系统安全补丁为最新日期。

5) IT 部定期检查远程访问的用户使用情况，及时删除无用的帐号。

11.2 分配 VPN 账号

需要通过外部网络访问应用程序的员工将获得一个 VPN 账号。远程访问的权限必须通过该账号登录至内网主机或使用公司设备（笔记本）。网络安全工程师必须记录 VPN 用户账号信息，分配员工的名字，工号，部门及使用范围。

11.3 遗忘 VPN 账号

如果 VPN 账号密码遗忘，应立即报告 IT 部。遗忘的 VPN 相关信息经记录后，确认使用人是否继续使用，并进行重发或禁用该账号。

11.4 废除 VPN

对无需继续使用的 VPN，用户应及时告知 IT，IT 应及时删除该 VPN 账号。

11.5 远程访问帐户的审查和监测

1) 定期对远程访问帐户的使用状况进行检查。

2) 定期对远程访问服务器的用户访问日志进行检查，发现潜在未经授权的登录请求。

3) 以上检查的信息的日志应被妥善保存。

12 密码安全保密制度

12.1 员工账户密码

1) 每个员工拥有一个公司内部计算机登录帐户，部门负责人根据公司要求在 AD 上申请为新员工开通账户。

2) 员工须妥善保管好自己的帐户和密码，严禁告知他人自己帐号密码，严禁互相询问打听他人帐号密码。

3) 设置密码时应注意：密码至少有 8 个字符长；密码必须包含以下任一部分：字母 A-Z 或 a-z，数字 0-9，特殊字符，例如 $ ，-等。

4) 提高安全认识，禁止他人操作使用自己电脑，一经发现立即报告部门主管。

5) 电脑必须设置带有密码的屏幕保护程序，屏保应设置 5 分钟，恢复登录时必须使用账户、密码登录

12.2 应用系统密码（WMS&JDY）

1）严禁将帐号密码透露给他人，让他人代己做系统操作；

2）员工调离岗位或离职时，所在部门的负责人应及时申请注销该员工的应用系统帐户。

3）加强口令管理，对文件用隐性密码方式保存，确认所有帐号都有口令，当系统中的帐号不再被使用时，应立即从相应的数据库中清除。

13 资料安全管理

13.1 文件的存储安全管理

1）所有部门人员应每周清理计算机中的文件，清除不需要的垃圾文件，将重要的文件和工作资料保存在特定的文件夹里，每月末应将电脑中的文件资料做一次备份，将文件资料备份到部门专用U盘或移动硬盘上，确保个人工作资料的文件归档，在电脑突发性故障或硬盘损坏时，能够及时恢复最近的工作资料；

2）电脑桌面上的文件应每周末拷贝到非系统盘符中、或不要在桌面存放任何工作性文件资料。若因个人原因未执行备份，造成数据资料丢失时，将由本人承担相关后果。

3）若员工离职，在办完离职手续后，所在部门负责人应联系IT部协助将此员工工作资料拷贝到部门U盘或移动硬盘上，若没有执行此安全过程，离职员工损失的文件资料由该部门承担。

13.2 日常工作信息安全

1） 员工应对在自己公司电脑内公司机密信息的安全负责，当电脑不需要使用或离开座位时必须立即启动带有密码的屏幕保护程序，防止他人随意登录使用电脑。

2） 员工有责任正确地保护分配给本人的所有计算机帐户。

3） 每台公司电脑内必须安装反病毒软件并启动实时扫描程序。信息管理部可以提供最新杀毒软件。

4） 不得安装有可能危及公司计算机网络的任何软件，若实在有需要进行软件测试的必须将计算机脱离公司计算机网络进行单机操作。

5） 任何对公司内部计算机网络的黑客行为是绝对禁止的，一经查实将按公司有关规定严肃处理。

6） 不要在任何地方谈论公司、客户的机密信息。

13.3 假期时间办公室的安全

1） 确保工作电脑的安全，在你离开之前的一周内备份你的文件。在你即将离开之际确保你的电脑关机并设有开机密码，其它信息管理部设备的电源也必须切断。

2） 确保你的存储介质，备份数据源和所有机密文件被妥善锁好。公司高度秘密和秘密信息在不用时必须总是被保存在设有密码锁或钥匙的柜中。公司的机密信息必须存放在锁上的办公桌或文件柜中。

14 涉密介质管理制度

14.1 计算机

1）涉密的计算机内的重要文件由专人集中加密保存,不得随意复制和解密,未经加密的重要文件不能存放在与国际联网的计算机上。

2）对报废的磁盘和其他存储设备中的秘密信息，需由技术人员进行彻底清除。

14.2 移动存储介质

1）涉密移动存储介质未经批准不得擅自带离本单位，确因工作需要携带外出的，须履行登记备案手续，并经领导批准。

2）严禁将涉密移动存储介质借给外单位或他人使用。

3）涉密移动存储介质需维修的通知 IT，由 IT 部门负责相关维修事宜。严禁个人、维修人员擅自读取和拷贝其存储资料。如涉密移动存储介质无法修复，必须按涉密载体予以销毁。

4）非涉密移动存储介质不得存储任何涉密信息。

5）非涉密移动存储介质不得连接涉密计算机。

6）不再使用、或不能使用的移动存储介质要及时上交办公室，由 IT 对要报废的移动存储介质进行进一步确认，并与领取时的类型，电子（产品）序列号，编号等进行核对，填写销毁登记表，经领导批准后进行销毁。

7）任何部门和个人不得擅自销毁移动存储介质。

15 员工安全培训

由集团总部定期通过在线方式进行安全培训，加强员工安全意识。